

CVEs más relevantes de la semana

Del 19/09/2026 al 26/09/2026

Porque el primer paso para defender es conocer las amenazas.



CVE-2026-75699

Descripción: Adobe Campaign Classic (ACC) is affected by an Improper Control of Generation of Code ('Code Injection') vulnerability that could result in arbitrary code execution in the context of the current user. An attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue does not require user interaction. Scope is changed.

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-09-22



CVE-2026-82009

Descripción: Adobe Campaign Classic (ACC) is affected by an Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') vulnerability that could result in arbitrary code execution in the context of the current user. An attacker with high privileges could exploit this vulnerability to execute arbitrary SQL commands. Exploitation of this issue does not require user interaction. Scope ...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-09-22



CVE-2026-82013

Descripción: Adobe Campaign Classic (ACC) is affected by a Server-Side Request Forgery (SSRF) vulnerability that could result in privilege escalation. A low-privileged attacker could exploit this vulnerability to gain elevated access to internal resources. Exploitation of this issue does not require user interaction. Scope is changed.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-918

Tecnología: No especificado

Publicado el: 2026-09-22



CVE-2026-82443

Descripción: Adobe Campaign Classic (ACC) is affected by a Server-Side Request Forgery (SSRF) vulnerability that could result in privilege escalation. A low-privileged attacker could exploit this vulnerability to gain elevated access to internal resources. Exploitation of this issue does not require user interaction. Scope is changed.

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:N

Tipo: CWE-918

Tecnología: No especificado

Publicado el: 2026-09-22



CVE-2026-83660

Descripción: Adobe Campaign Classic (ACC) is affected by a Server-Side Request Forgery (SSRF) vulnerability that could result in privilege escalation. Exploitation of this issue does not require user interaction. Scope is changed.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:L/A:L

Tipo: CWE-918

Tecnología: No especificado

Publicado el: 2026-09-22



CVE-2026-89276

Descripción: Adobe Campaign Classic (ACC) is affected by an Improper Control of Generation of Code ('Code Injection') vulnerability that could result in arbitrary code execution in the context of the current user. A low-privileged attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue does not require user interaction. Scope is changed.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:L

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-09-22



CVE-2026-75684

Descripción: Adobe Connect is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by an attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field, potentially gaining elevated access or control over the victim's account or session. Scope is changed.

CVSS: 9.3 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:N

Tipo: CWE-79

Tecnología: No especificado

Publicado el: 2026-09-22



CVE-2026-28324

Descripción: SolarWinds Observability Self-Hosted was found to be affected by an unauthenticated remote code execution vulnerability due to the insufficient integrity checks. Installations configured in a non-default and non-secure configuration are affected.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-345

Tecnología: No especificado

Publicado el: 2026-09-22



CVE-2026-96754

Descripción: orval versions before 8.29.0 contain a code injection vulnerability in the @orval/hono generator that fails to escape OpenAPI path values in single-quoted route literals. Attackers can craft an OpenAPI document with an apostrophe in a static path segment to inject arbitrary JavaScript code that executes when the generated TypeScript module is imported.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-09-23



CVE-2026-96755

Descripción: orval versions 8.14.0 through 8.28.1 contain a code injection vulnerability in the @orval/effect generator that converts OpenAPI schema defaults into template literals. Attackers can inject arbitrary JavaScript expressions via schema defaults containing `${...}` syntax, which are executed at module scope when the generated code is built or imported.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-09-23



CVE-2026-96759

Descripción: orval before 8.29.0 fails to escape the operationId parameter when emitting it into generated TanStack Query mutator options metadata objects. Attackers can inject arbitrary JavaScript code through a crafted operationId in an OpenAPI specification that executes when generated hooks are called.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-09-23



CVE-2026-97359

Descripción: HFS2 version 2.4.0 and earlier contains a template injection vulnerability in the multipart upload handler that allows unauthenticated attackers to achieve remote code execution by embedding malicious template syntax in a filename. Attackers can craft a filename containing a closing template quoting sequence followed by an exec macro, which bypasses the authorization check in the dispatcher to ...

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-1336

Tecnología: No especificado

Publicado el: 2026-09-24



CVE-2026-93399

Descripción: The Bookly plugin for WordPress is vulnerable to Insecure Direct Object Reference in versions up to, and including, 28.2 via the 'bookly_get_form_id', 'bookly_render_complete', 'bookly_add_to_calendar' and 'bookly_rollback_order' AJAX actions. This is due to the 'bookly_get_form_id' handler blindly storing the attacker-controlled 'order_id' from the submitted form_data into a new booking sessio...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: CWE-639

Tecnología: No especificado

Publicado el: 2026-09-25



CVE-2026-97063

Descripción: X-SpringBoot through 6.0 returns login verification codes in HTTP responses from unauthenticated endpoints GET /sys/mobile/code and GET /sys/email/code without sending them to account owners. Attackers can request codes using known mobile numbers or email addresses, read them from responses, and authenticate as victims via POST /sys/emailOrMobileLogin/login to hijack accounts.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-09-25



CVE-2026-97064

Descripción: X-SpringBoot through 6.0 ships with a hardcoded static master login verification code 172839 enabled by default in the database seed. Unauthenticated attackers can authenticate as any user by submitting the public master code to the emailOrMobileLogin endpoint with a known email or mobile number.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-1392

Tecnología: No especificado

Publicado el: 2026-09-25



CVE-2026-18143

Descripción: The Request a Quote for WooCommerce plugin for WordPress is vulnerable to Arbitrary File Upload in all versions up to, and including, 2.9.2 via the ``afrfq_submit_quote_via_popup()`` function. This is due to missing file extension and MIME type validation in the popup upload handler, which uses the raw attacker-supplied filename directly as the destination for ``move_uploaded_file()``. This makes i...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-434

Tecnología: No especificado

Publicado el: 2026-09-26



CVE-2026-100706

Descripción: kyverno before 1.19.1 fails to properly validate URL-encoded path segments in Policy apiCall urlPath, allowing namespace tenants to bypass the per-namespace clamp and create objects in other namespaces as the admission-controller ServiceAccount. Attackers can exploit this by using percent-encoded directory traversal sequences to create MutatingWebhookConfiguration objects cluster-wide or Policy...

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-441

Tecnología: No especificado

Publicado el: 2026-09-26



CVE-2026-100714

Descripción: Froxlor before 2.3.12 does not restrict or escape the `system.letsencryptchallengepath` setting: unlike sibling settings hardened in GHSA-33mp, the field has no `string_regexp` or `required_opt` guard, and its value is concatenated unescaped into the `acme.sh` command line built in `lib/Froxlor/Cron/Http/LetsEncrypt/AcmeSh.php` and executed by the root cron via `FileDir::safe_exec`. Because `safe_exec` only ...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-88

Tecnología: No especificado

Publicado el: 2026-09-26



CVE-2026-100715

Descripción: Froxlor through 2.3.10 is vulnerable to arbitrary file deletion via symlink following in the FTP data deletion cron task. Cron task 8 (deleteFtpData), queued when an FTP account is deleted, calls FileDir::makeCorrectDir() without the \$fixed_homedir argument, so the symlink component walk is skipped, and then executes 'rm -rf' as root on the resulting path with string-level guards only. Because ...

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:N/I:H/A:H

Tipo: CWE-59

Tecnología: No especificado

Publicado el: 2026-09-26



CVE-2026-100716

Descripción: Froxlor is a server administration panel. In versions 2.3.10 and earlier, the customer data-export (DataDump) cron fails to validate intermediate path components of the export destination: Froxlor\FileDir::makeCorrectDir() contains an off-by-one in its path-component walk that skips the first segment below the customer home directory, and the guard in ExportCron.php checks only the final compon...

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-59

Tecnología: No especificado

Publicado el: 2026-09-26



CVE-2026-100717

Descripción: froxlor is a server administration panel. In versions 2.3.10 and earlier, Validate::validateUrl rejects carriage return and line feed characters only in the path, query and fragment components returned by parse_url, and never inspects the userinfo (user:pass@) components. This is an incomplete fix for GHSA-c3p2. An authenticated low-privilege customer with subdomain-create rights (no admin or c...

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:L/I:H/A:H

Tipo: CWE-93

Tecnología: No especificado

Publicado el: 2026-09-26



Resumen del Reporte

CVEs analizados: 21

Promedio CVSS: 9.64

Fuente: nvd.nist.gov

Nos vemos la próxima semana. Hack the Cat ☹

